พื้นฐาน DevSecOps: ความปลอดภัยที่รวมอยู่ในทุกขั้นตอนของการพัฒนา

หลักการพื้นฐานและแนวปฏิบัติ (Core Principles & Practices)



การ Shift-Left Security

เริ่มต้นตรวจสอบความปลอดภัยตั้งแต่ระยะแรกของการพัฒนาเพื่อลดต้นทุนในการแก้ไขปัญหา



ระบบความปลอดภัยอัตโนมัติ (Automation)

ผสมผสานการตรวจสอบความปลอดภัยเข้ากับ CI/CD Pipeline โดยอัตโนมัติในทุกการแก้ไขโค้ด



ความรับผิดชอบร่วมกัน (Collaboration)

ทีมพัฒนา (Dev), ทีมความปลอดภัย (Sec) และทีมปฏิบัติการ (Ops) ต้องทำงานร่วมกันอย่างใกล้ชิด

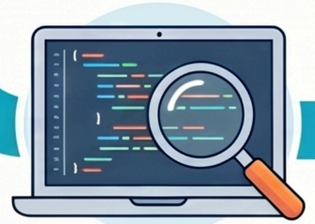


SAST ตรวจสอบ Source Code ก่อนรัน



ส่วน DAST ตรวจสอบแอปพลิเคชันขณะที่ทำลังทำงานอยู่

เครื่องมือและการทดสอบที่สำคัญ (Essential Testing & Tools)



SAST vs DAST

ตรวจสอบ Source Code ก่อนรัน



การจัดการความลับ (Secrets Management)

ใช้เครื่องมืออย่าง HashiCorp Vault หรือ AWS Secrets Manager เพื่อจัดเก็บรหัสผ่านและ API Keys ให้ปลอดภัย



การสแกน Container และ Library

ตรวจสอบช่องโหว่ใน Third-party Library และ Container Images ก่อนนำไปใช้งานจริง

ตัวอย่างเครื่องมือ DevSecOps

ประเภทการทดสอบ	ตัวอย่างเครื่องมือ
Code Security / SAST	SonarQube, Snyk, Checkmarx
Dynamic Testing / DAST	OWASP ZAP, Burp Suite
Container Scanning	Trivy, Anchore, Clair

NotebookLM